

CHALLENGE #7: Power Cookie Write-up.

Power Cookie

Medium

Web Exploitation

picoCTF 2022

cookie

AUTHOR: LT 'SYREAL' JONES

Description

Can you get the flag?
Go to this [website](#) and see what you can discover.

This challenge launches an instance on demand.
Its current status is: **RUNNING**
Instance Time Remaining: **14:51**

Restart Instance

Hints

1

Do you know how to modify cookies?

37,450 users solved

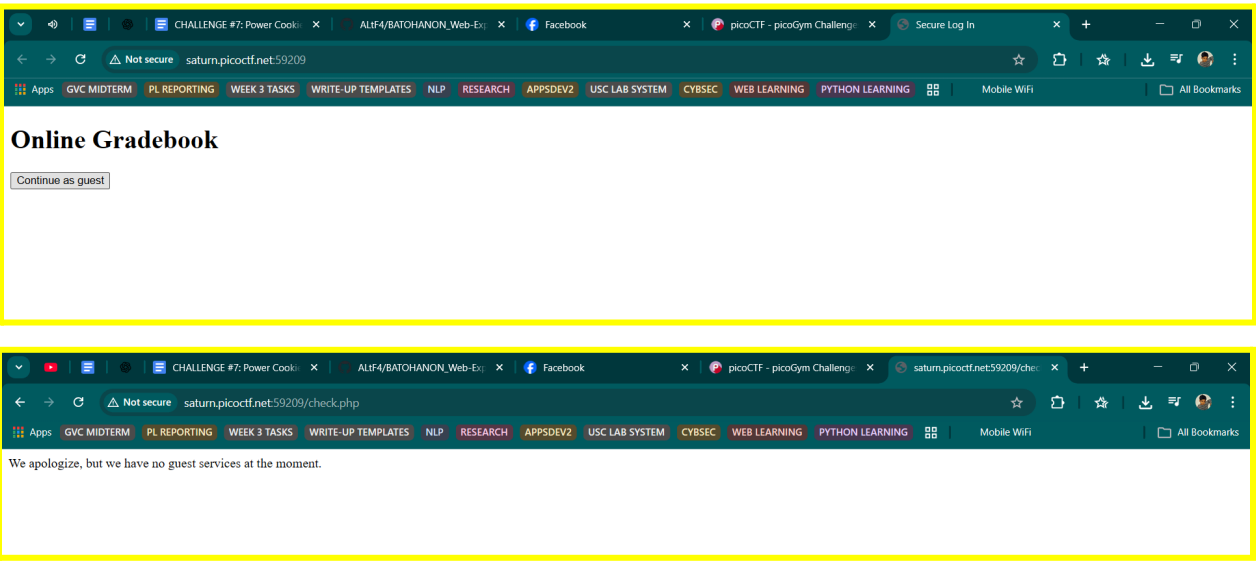
90% Liked

picoCTF{FLAG}

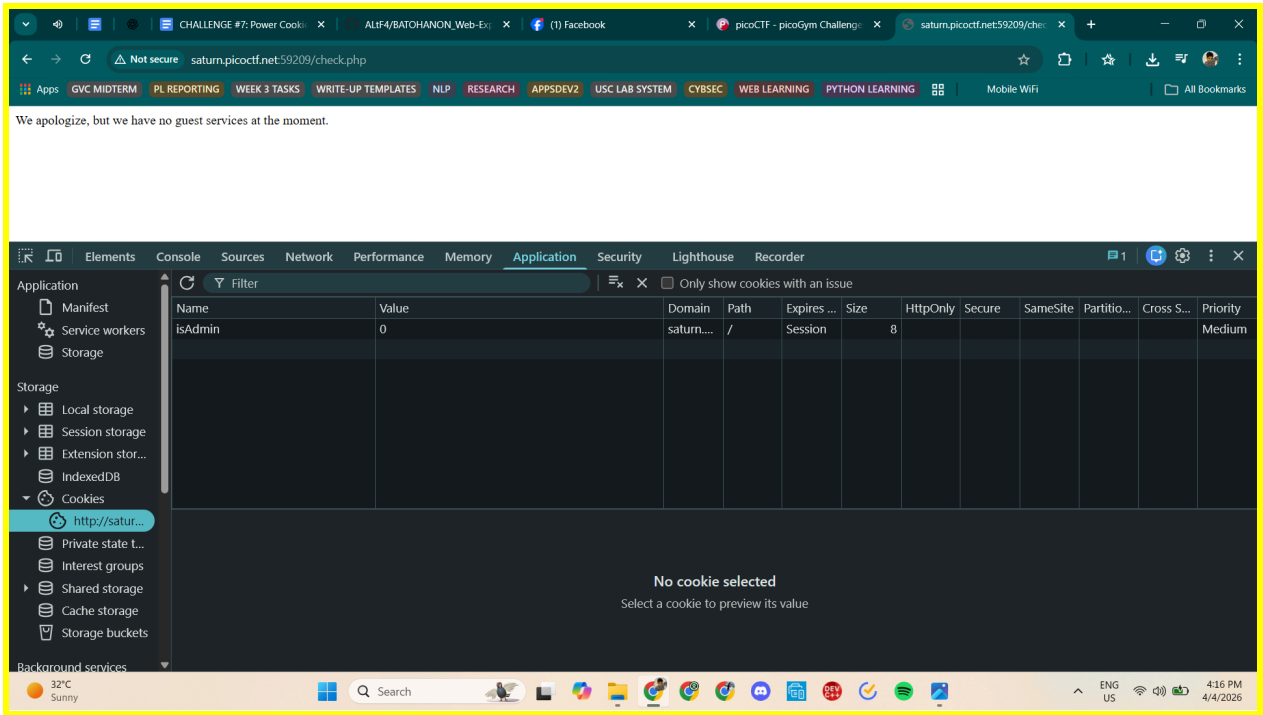
Submit Flag

Solving Process:

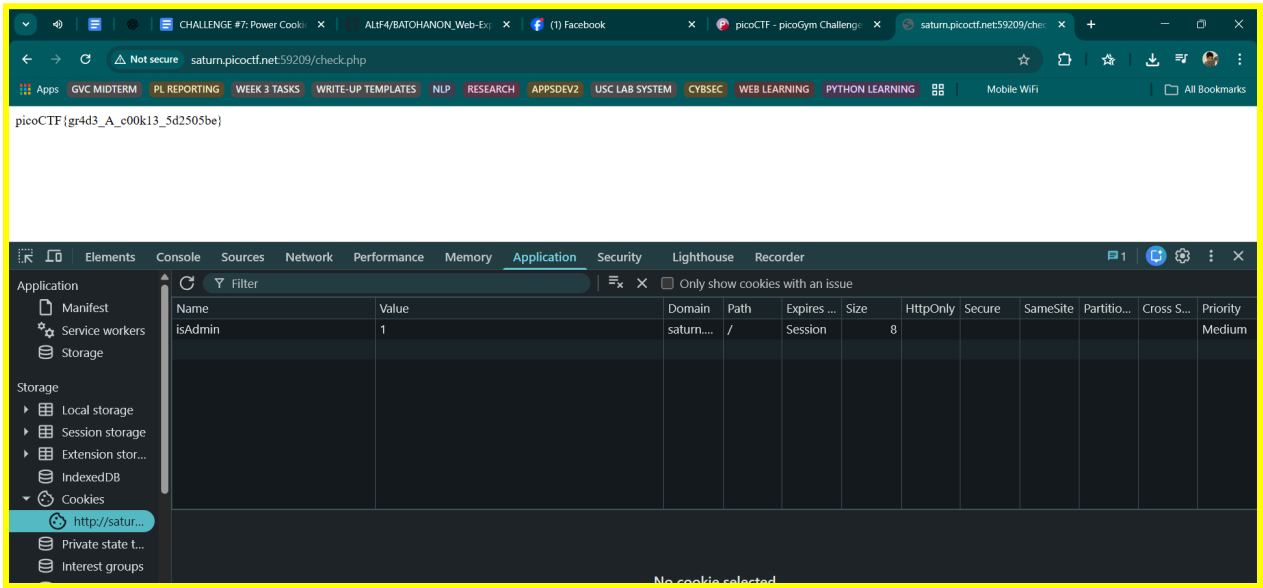
First, the challenge instance was launched and the provided website link was opened in a new browser tab. The website displayed a simple **online grade book** page with an option to Continue as Guest. After clicking this option, the site redirected to another page located at check.php, which displayed the message stating that there were currently no guest services available.



Since the challenge title was Power Cookie, it suggested that the vulnerability likely involved manipulating HTTP cookies. To investigate this, I examined the site's Cookies via the browser's inspection tools. Inside the cookies list, a cookie named **isAdmin** was found. Its value was set to **0**, which likely represented a boolean value indicating that the current user was not an administrator. This suggested that the website might be relying on the cookie value to determine whether a user has administrative privileges.



To test this assumption, the value of the **isAdmin** cookie was edited directly in the browser's cookie storage. The value was changed from **0** to **1**, effectively switching the status from false to true. After modifying the cookie value, the page was refreshed.



Upon reloading the page, the website immediately recognized the modified cookie as an administrator session, and the page displayed the flag, confirming that the privilege escalation was successful. This demonstrated that the application relied solely on the client-side cookie value to determine administrative access, making it vulnerable to cookie manipulation attacks.

Medium

Web Exploitation

picoCTF 2022

cookie

AUTHOR: LT 'SYREAL' JONES

Description

Can you get the flag?
Go to this [website](#) and see what you can discover.

This challenge launches an instance on demand.
Its current status is: **RUNNING**
Instance Time Remaining: **14:55**

Restart Instance

Hints

1
Do you know how to modify cookies?

37,450 users solved

90%
Liked

picoCTF{gr4d3_A_c00k13_5d2505be}

Submit Flag

Hurray! You solved this challenge.

Reflection:

This challenge showed how relying on client-side cookies for access control can create serious security vulnerabilities. By simply modifying the cookie value from 0 to 1, administrative privileges were granted without any server-side verification. It also demonstrated that using simple boolean values for role checking (such as 0 for user and 1 for admin) can make privilege escalation very easy for attackers. The activity emphasized the importance of server-side validation, secure session management, and proper role-based access controls to prevent unauthorized access.